

🔥 Advanced BadUSB Capabilities (ESP32-S3 + CircuitPython)

⚠️ LEGAL WARNING

These techniques are for authorized penetration testing, red team exercises, and security research on systems you OWN or have **WRITTEN PERMISSION** to test. Unauthorized access to computer systems is illegal.

🎯 What You Can Do (From Mild to Wild)

1. 🔑 Credential Harvesting

- **WiFi Passwords:** Dump all saved WiFi profiles with passwords
- **Browser Passwords:** Steal Chrome, Firefox, Edge saved passwords
- **LSASS Memory Dump:** Extract credentials from Windows memory
- **SAM Database:** Copy Windows SAM/SYSTEM hives for offline cracking

2. 🔄 Reverse Shells

- **PowerShell TCP Reverse Shell:** Connect back to your machine
- **Netcat Listener:** Full remote command execution
- **DNS Tunneling:** Exfiltrate data via DNS queries
- **HTTPS Beacon:** Encrypted C2 communication

3. 🕷️ Persistence Mechanisms

- **Registry Run Keys:** Auto-start on login
- **Scheduled Tasks:** Run every X minutes
- **WMI Event Subscriptions:** Event-driven backdoor
- **Startup Folder:** Classic persistence
- **Service Creation:** Run as SYSTEM
- **DLL Hijacking:** Inject into legitimate apps

4. 🛡️ Evasion & Anti-Forensics

- **Disable Windows Defender:** Turn off real-time protection
- **Disable Firewall:** Open all ports
- **Clear Event Logs:** Delete Security, System, Application logs
- **Clear PowerShell History:** Remove command traces
- **Process Injection:** Hide in legitimate processes
- **AMSI Bypass:** Bypass Windows script scanning

5. 📹 Surveillance

- **Screenshots:** Capture screen every X seconds
- **Webcam Snapshots:** Take photos via camera
- **Audio Recording:** Record microphone input
- **Keylogger:** Log all keystrokes (needs separate hardware usually)

6. 🧨 Destructive (DON'T DO THIS)

- **Ransomware Simulation:** Encrypt files (test environment only!)
- **Data Wiping:** Delete critical files
- **Registry Corruption:** Break Windows boot
- **BIOS/UEFI Flashing:** Brick the machine

7. 🌐 Network Attacks

- **ARP Spoofing:** Man-in-the-middle on local network
- **DNS Hijacking:** Redirect traffic via hosts file
- **Proxy Settings:** Route all traffic through your server
- **WiFi Pineapple:** Create rogue access points

8. 📁 Data Exfiltration

- **File Collection:** Grab documents, PDFs, databases
- **Cloud Token Theft:** Steal Dropbox, OneDrive, Google Drive tokens
- **Email Harvesting:** Export Outlook PST files
- **SSH Key Theft:** Grab ~/.ssh/ private keys

🔧 The Advanced Payload I Built

The `payload_advanced.txt` includes:

Feature	Status
Disable Windows Defender	✓
Steal Chrome passwords	✓
Steal Firefox passwords	✓
WiFi password dump	✓
Screenshot capture	✓
LSASS memory dump	✓
Scheduled Task persistence	✓
Registry Run key	✓
WMI Event Subscription	✓
Reverse shell script	✓
Clear event logs	✓
Clear PowerShell history	✓

⚠️ **IMPORTANT:** Change `192.168.1.100` to YOUR IP address before running!

🚀 How to Use the Advanced Payload

Step 1: Setup Your Listener

On your attacking machine (Kali/Parrot/etc):

```
# For reverse shell
nc -lvp 4444

# For file exfiltration
python3 -m http.server 8080
```

Step 2: Prepare the Payload

1. Open `payload_advanced.txt`
2. Replace ALL instances of `192.168.1.100` with YOUR IP
3. Save as `payload.txt` on CIRCUITPY

Step 3: Execute

1. Plug ESP32-S3 into target
2. Press BOOT button
3. Wait ~60 seconds
4. Check your listener!

Defensive Recommendations

If you're a blue teamer reading this:

- Disable USB ports via Group Policy
- Use USB device control software
- Monitor for new HID devices
- Alert on cmd/powershell spawned by unknown processes
- Monitor registry run keys and scheduled tasks
- Enable PowerShell script block logging
- Use AppLocker/WDAC to block unsigned scripts

Learning Resources

- [Hak5 USB Rubber Ducky](#)
- [PayloadsAllTheThings](#)
- [Windows Red Team Notes](#)
- [MITRE ATT&CK Framework](#)